

SCS-C03 Speed-Run Cheat Sheet

AWS Certified Security – Specialty · print/final-review edition

65 Q (50 scored + 15 unscored) | 170 min | \$300 USD | Pass at 750/1000 | Ordering + matching Qs, no partial credit | Live since Dec 2, 2025

Ordered by exam weight, highest first, so your review time goes where the points are. Each domain: the services that actually get tested, the trigger phrase that should make you think of them, the specific traps AWS likes to set, and one memory hook. Domain weights — IAM 20% · Infrastructure Security 18% · Data Protection 18% · Detection 16% · Incident Response 14% · Governance 14%.

D4 Identity & Access Management

20%

Identity IS the perimeter. One in five questions lives here directly — and IAM logic quietly decides the answer in most of the other domains too.

CONCEPT	WHAT IT DOES	TRIGGER PHRASE
Policy evaluation	Explicit DENY always wins. Otherwise every applicable layer — SCP/RCP, resource policy, identity policy, boundary, session policy — must line up to ALLOW.	<i>why was this denied</i>
Same-account access	Identity-based OR resource-based ALLOW is enough on its own.	<i>one account, two policies</i>
Cross-account access	BOTH sides must allow — the role's trust policy AND the caller's permission to assume it.	<i>account A needs into account B</i>
Permission Boundary	A ceiling on what a policy can grant. Grants nothing by itself.	<i>let devs create roles safely</i>
ABAC vs RBAC	ABAC: tag-match, zero new policies as resources grow. RBAC: one role per job function.	<i>scale without new policies</i>
IAM Identity Center	Workforce SSO across many accounts via permission sets.	<i>SSO across the whole org</i>
Cognito	Customer-facing app login, issues JWTs, feeds STS for AWS creds.	<i>mobile/web app users</i>
External ID	Stops a third party being tricked into misusing your role (confused deputy).	<i>vendor assumes our role</i>

RED-FLAG TRAPS

- STS temporary credentials can't be revoked one-by-one — block them with a policy condition on **TokenIssueTime**.
- KMS key policy is the one resource policy that's mandatory — IAM alone can't unlock a key unless the key policy enables IAM.
- S3 presigned URLs inherit the signer's permissions and expire — a leaked URL is only as dangerous as the signing role's session.
- Session policies and permission boundaries never grant — the effective permission is always the intersection.

MEMORY HOOK: “Deny beats all. Cross-account needs both hands to clap.”

Lock down the edge, the compute, and the network — in layers, not one giant control.

CONCEPT	WHAT IT DOES	TRIGGER PHRASE
AWS WAF	Layer-7 filtering (SQLi, XSS, bots). Attaches to CloudFront / ALB / API Gateway / AppSync only — never NLB, never EC2 directly.	<i>SQL injection / bad bots</i>
Shield Standard vs Advanced	Standard: free, automatic, L3/4. Advanced: paid, 24/7 SRT team, cost protection, auto WAF deployment.	<i>SRT / DDoS cost protection</i>
Security Group vs NACL	SG: stateful, allow-only, instance-level. NACL: stateless, allow+deny, subnet-level, needs ephemeral return ports.	<i>block one specific IP → NACL</i>
Network Firewall	Managed stateful firewall — domain filtering, IDS/IPS — for when SG/NACL isn't granular enough.	<i>east/west inspection between VPCs</i>
Session Manager	SSH/RDP-free, fully audited admin access. No open ports, no bastion.	<i>auditable interactive access</i>
Inspector	Continuous CVE scanning across EC2 / ECR / Lambda.	<i>known vulnerabilities</i>
Bedrock Guardrails	Content filters, PII redaction, prompt-injection defense for GenAI apps. New in C03.	<i>secure our LLM app</i>

RED-FLAG TRAPS

- Site-to-Site VPN = encrypted by default. Direct Connect = private but NOT encrypted — add a VPN or MACsec on top.
- IMDSv2 (token-based) defeats SSRF credential theft — enforce fleet-wide with HttpTokens=required.
- Security groups can only allow — they can never explicitly deny.
- Never put secrets in EC2 user data.

MEMORY HOOK: “SG says yes-only and remembers you. NACL says yes-or-no and forgets you.”

D5 Data Protection

18%

Encrypt everything, control every key. KMS is very likely the single most-tested service on your whole exam.

CONCEPT	WHAT IT DOES	TRIGGER PHRASE
Envelope encryption	KMS encrypts a data key; the data key encrypts your actual data. Data never round-trips through KMS itself.	<i>how KMS scales to large data</i>
SSE-S3 / SSE-KMS / SSE-C	AWS holds the key (default) / you control key policy + audit trail / you supply the key per request.	<i>bring your own key per object → SSE-C</i>
CloudHSM	Single-tenant dedicated hardware, FIPS 140-2 Level 3.	<i>full key custody / dedicated HSM</i>
Secrets Manager vs Parameter Store	Secrets Manager: automatic rotation + cross-account resource policies. Parameter Store: cheaper, SecureString, no native rotation.	<i>rotate DB credentials automatically</i>
S3 Object Lock	Compliance mode: unbreakable, even by root. Governance mode: bypassable with a permission.	<i>nobody can delete this, ever → Compliance</i>
Imported key material (BYOK)	No auto-rotation; you can expire/delete on demand; AWS can't recover it if you lose your copy.	<i>bring your own key material</i>

RED-FLAG TRAPS

- Unencrypted EBS volumes can't be encrypted in place — snapshot, copy-with-encryption, restore.
- RDS encryption must be set AT creation — same snapshot-copy-restore workaround applies afterward.
- DynamoDB is always encrypted at rest — the only choice is which key type.
- "Immutable" almost always means Object Lock — don't overthink it with a custom build.

MEMORY HOOK: "KMS wraps the key, not the whole cake."

You can't secure what you can't see. Monitoring, logging, and alerting across every account.

CONCEPT	WHAT IT DOES	TRIGGER PHRASE
GuardDuty	Automated threat detection from CloudTrail, VPC Flow Logs & DNS logs — already running, nothing to enable.	<i>something's behaving maliciously now</i>
Security Hub	Aggregates GuardDuty + Inspector + Macie + Config findings; scores against CIS/AWS standards.	<i>one dashboard for everything</i>
Macie	Scans S3 for PII/sensitive data + evaluates bucket posture.	<i>which buckets hold PII</i>
Inspector	Scans EC2/ECR/Lambda for CVEs — vulnerabilities, not active behavior.	<i>known vulnerabilities (vs GuardDuty)</i>
CloudTrail	Records every API call — who did what.	<i>audit trail of account activity</i>
VPC Flow Logs	Records network traffic ACCEPT/REJECT.	<i>what happened at the network layer</i>
Security Lake	Normalizes logs org-wide into OCSF format for a SIEM. New in C03.	<i>centralize logs in a standard schema</i>
EventBridge	Routes findings/events into automated response.	<i>the glue between detection and action</i>

RED-FLAG TRAPS

- GuardDuty (behavior) vs Macie (sensitive data) vs Inspector (CVEs) are three different jobs — all feed Security Hub.
- CloudTrail (API calls) vs VPC Flow Logs (network packets) answer different questions.
- Classic alert chain: metric filter on a log pattern → CloudWatch alarm → SNS. Know this shape cold.

MEMORY HOOK: “GMI reports to the Hub — GuardDuty, Macie, Inspector → Security Hub.”

D2 Incident Response

14%

Contain it, preserve the evidence, recover — in that exact order. Ordering questions live here.

CONCEPT	WHAT IT DOES	TRIGGER PHRASE
Isolation security group	Move the compromised instance into an SG with zero rules; pull it from the ASG/load balancer.	<i>contain without destroying evidence</i>
EBS snapshot	Capture disk state before touching anything else.	<i>preserve evidence first</i>
Detective	Behavior graph — what did this actor/IP/instance actually do.	<i>root-cause the finding</i>
Credential response	Deactivate access key → revoke role session → rotate secrets → review CloudTrail.	<i>credentials may be compromised</i>
EventBridge → Lambda/SSM/Step Functions	The standard auto-remediation chain.	<i>respond without a human in the loop</i>

RED-FLAG TRAPS

- Favorite ordering sequence: **Snapshot → Isolate → Tag for forensics → never terminate before evidence capture.**
- Terminating an instance loses volatile memory; tightening a security group does NOT kill live connections.
- Object Lock Governance mode is bypassable with a permission; Compliance mode is unbreakable, even by root, until retention expires.

MEMORY HOOK: “SIT, don’t kill it — Snapshot, Isolate, Tag.”

D6 Security Foundations & Governance

14%

Enforce the rules across hundreds of accounts, automatically, forever.

CONCEPT	WHAT IT DOES	TRIGGER PHRASE
SCP	Caps permissions on principals in member accounts. Never grants. Doesn't touch the management account.	<i>org-wide guardrail on accounts</i>
RCP (new in C03)	Caps what resource-based policies can allow, org-wide — the "other side" of SCP.	<i>org-wide guardrail on resource policies</i>
Control Tower	Automates landing-zone setup + guardrails at scale, built on Organizations.	<i>stand up a multi-account landing zone</i>
Delegated administrator	Lets a member account run GuardDuty/Security Hub org-wide, without the management account.	<i>manage security without root access</i>
AWS Config	Continuously assesses configs against rules, auto-remediates via SSM.	<i>continuous compliance checking</i>
Audit Manager	Continuous evidence collection for compliance frameworks.	<i>gather audit evidence automatically</i>

RED-FLAG TRAPS

- SCPs and RCPs are ceilings, not grants — an underlying IAM allow still has to exist.
- SCPs never apply to the management account or to service-linked roles.
- "Guardrail on accounts" = SCP. "Guardrail on resource policies" = RCP. Read the question carefully.

MEMORY HOOK: “SCP caps who. RCP caps what they’re touching. Neither one says yes.”

60-Second Rapid Recall

The keyword-to-answer index. Skim this the morning of the exam — if a scenario uses one of these phrases, the answer on the left maps to the answer on the right.

TRIGGER IN THE QUESTION	ANSWER
immutable	S3 Object Lock (Compliance mode = unbreakable)
single-tenant hardware / FIPS 140-2 Level 3	CloudHSM
zero-trust app access without a VPN	AWS Verified Access
org-wide guardrail on accounts/principals	Service Control Policy (SCP)
org-wide guardrail on resource policies	Resource Control Policy (RCP)
SSH/RDP without open ports, fully audited	Systems Manager Session Manager
SSRF / stolen instance metadata credentials	Enforce IMDSv2
which buckets contain PII	Amazon Macie
known CVEs in EC2 / ECR / Lambda	Amazon Inspector
something is actively behaving maliciously	Amazon GuardDuty
one dashboard for all security findings	AWS Security Hub
centralize logs org-wide, standard schema, SIEM	Amazon Security Lake (OCSF)
third party assuming your role (confused deputy)	External ID condition
safe delegated IAM administration	Permissions Boundary
scale access without a new policy per resource	ABAC (tag-based access)
workforce SSO across many accounts	IAM Identity Center (permission sets)
customer-facing app login / JWTs	Amazon Cognito
rotate database credentials automatically	AWS Secrets Manager
cheap config storage, no rotation needed	SSM Parameter Store (SecureString)
block one specific IP address	Network ACL (SGs can't deny)
encrypted by default over the public internet	Site-to-Site VPN
private connection but NOT encrypted by itself	Direct Connect (+VPN or MACsec)
domain filtering / IDS/IPS between VPCs	AWS Network Firewall
GenAI app guardrails / prompt injection	Amazon Bedrock Guardrails
evidence must survive root trying to delete it	S3 Object Lock – Compliance mode
can't revoke stolen temp credentials one-by-one	Deny condition on TokenIssueTime
bring your own encryption key material	KMS imported key material (BYOK)
mask sensitive data in logs / in-flight messages	CloudWatch Logs / SNS data protection
run security services for the whole org, one place	Delegated administrator account

EC2 compromised – what order do I act

**Snapshot → Isolate → Tag → never
terminate first**

Built from the official SCS-C03 exam guide (v1.0, live since Dec 2, 2025). Domain weights: IAM 20 · Infrastructure Security 18 · Data Protection 18 · Detection 16 · Incident Response 14 · Governance 14. Always cross-check against AWS's current exam guide before your test date.